ACP Assessment Questionnaire

This questionnaire supports assessors and organizations in performing an **Active Cyber Program (ACP) Assessment** or self-assessment.

Each row corresponds to one control of the ACP assessment checklist (`assessment/assessment-checklist.md`). The guiding questions help determine **one score per control**. Questions are not scored individually.

Framework version: **ACP 2.1**

How to Use

1. Complete the organization profile and confirm the assessment scope, including whether the AI Security domain (Domain 11) is applicable.
2. For each control, work through the guiding questions with the responsible persons. If IT operations are outsourced, include the IT service provider; the organization remains responsible.
3. Ask to be shown the evidence named in the scoring guidance and record what was reviewed (document name, system, screenshot, interview).
4. Assign one score per control. Use N/A only where permitted by the scoring model.
5. Calculate domain scores and the overall ACP score as defined in `assessment/scoring-model.md`.

Score	Meaning	Description
0	Not Implemented	The control does not exist, is not implemented, or no evidence is provided.
1	Partially Implemented	The control exists but is incomplete, inconsistently applied, or covers only part of the scope.
2	Implemented	The control is implemented across the scope, documented, and evidence shows that it is operating.
3	Actively Managed	In addition, the control is monitored, reviewed at defined intervals and improved over time.

Controls marked **[KO]** are knock-out controls. A score of 0 prevents certification. Knock-out controls cannot be marked N/A.

Scoring guidance. The column *Scoring guidance* names typical evidence and what typically distinguishes score 2 from score 3. It supports, but does not replace, the assessor's judgement. Score 1 applies if the control exists only partially.

Controls with several parts. If a control covers several aspects, the weakest essential aspect determines the score.

Proportionality. Small organizations do not need extensive documentation. Short, clear rules are sufficient if they are applied in practice and can be shown.

Assessment Information

Organization:

Assessment date:

Assessor:

AI Security domain applicable: □ Yes □ No

Organization Profile

The profile describes the context of the assessment. It is not scored.

Topic	Answer
Number of employees and locations	
IT operations (internal, IT service provider, mixed)	
Main cloud and SaaS services (e.g., Microsoft 365)	
Use of AI tools or AI systems	
Applicable regulations (e.g., NIS2, Swiss Information Security Act, FADP/GDPR, DORA)	
Customers in regulated sectors (e.g., financial sector under DORA)	
Security incidents in the last 12 months	
Cyber insurance	
Existing certifications or audits (e.g., ISO/IEC 27001)	

Domain 1 – Business & Security Governance (critical)

ID	Control	Guiding questions	Scoring guidance	Score	Evidence / Notes
1.1	A cybersecurity strategy is documented	• Is a documented cybersecurity or information security strategy in place? • Has the strategy been approved by executive management? • When was the strategy last reviewed?	**Show:** Strategy document with approval date **2:** Strategy documented and approved by management **3:** Reviewed at least annually and adjusted to changes		
1.2	Cybersecurity objectives are defined and aligned with business goals	• Are cybersecurity objectives defined and documented? • Are the objectives derived from business goals? • Are the objectives reviewed regularly?	**Show:** List of security objectives **2:** Objectives defined and linked to business goals **3:** Progress is measured and objectives are reviewed regularly		
1.3	Security responsibilities are assigned within the organization	• Are responsibilities for cybersecurity defined? • Is a person accountable for cybersecurity named (e.g., CISO, information security officer)? • Are deputies defined?	**Show:** Organization chart or role description with security responsibilities **2:** Responsible person and deputy named, tasks defined **3:** Responsibilities are reviewed, and the role has sufficient time and budget		
1.4	Security topics are discussed at management level	• Are cybersecurity topics discussed regularly in management meetings? • Are decisions on cybersecurity documented?	**Show:** Minutes of management meetings with security topics **2:** Security is discussed at least quarterly, decisions are recorded **3:** Standing agenda item, implementation of decisions is tracked		
1.5	Security initiatives are planned and tracked	• Is there a roadmap for security measures? • Do measures have owners, budgets and deadlines? • Is progress tracked?	**Show:** Security roadmap or action list **2:** Measures have owners, deadlines and budget **3:** Progress is reviewed regularly, priorities are adjusted		
1.6	Security reporting to leadership exists	• Does management receive regular security reports? • Are the results of security assessments communicated to management?	**Show:** Latest security report to management **2:** Management receives a security report at least every six months **3:** Reports contain metrics and trends and lead to documented decisions		

Domain score:

Domain 2 – Risk Management

ID	Control	Guiding questions	Scoring guidance	Score	Evidence / Notes
2.1	Cybersecurity risks are formally identified	• Is there a process to identify cybersecurity risks? • Are risks reassessed when systems or processes change? • Are cloud risks considered?	**Show:** Description of the risk process, latest risk identification **2:** Risks are identified using a defined approach **3:** Risks are reassessed after changes and at least annually		
2.2	A risk register exists	• Is a risk register maintained? • Does each risk have an owner?	**Show:** Risk register **2:** Register is current, each risk has an owner **3:** Register is used for decisions and updated regularly		
2.3	Risks are evaluated based on impact and likelihood	• Is a documented risk assessment methodology in place? • Are risks rated by likelihood and impact?	**Show:** Rating scale and rated risks **2:** All risks are rated using a documented scale **3:** Ratings are traceable and reviewed when the situation changes		
2.4	Risk mitigation measures are defined	• Are mitigation measures defined for relevant risks? • Are measures tracked to completion? • Is the acceptance of residual risks formally approved? • Is risk transfer (e.g., cyber insurance) considered, and are the insurer's requirements and notification obligations known?	**Show:** Risk treatment plan, accepted residual risks **2:** Measures defined for relevant risks, residual risks formally accepted **3:** Effectiveness of measures is checked, risk transfer (e.g., insurance) is considered deliberately		
2.5	Risk reviews are conducted periodically	• Are risks reviewed at defined intervals? • When was the last review performed?	**Show:** Date and result of the last risk review **2:** Risks are reviewed at least annually **3:** Additional event-driven reviews (e.g., after incidents or changes)		
2.6	Supply chain risks are assessed and security requirements are agreed with critical suppliers	• Are critical suppliers and service providers identified? • Are their security risks and practices assessed before and during the relationship, including secure development practices of software suppliers? • Are security requirements included in contracts with critical suppliers? • If IT operations are outsourced (e.g., to an IT service provider): are responsibilities for security agreed in writing? • If you have customers in the financial sector (e.g., under DORA): are your contractual obligations known, and can you meet them (e.g., incident notification and assistance, access and audit rights, participation in tests, exit support including the return of data)? • If you have customers in the financial sector: can you provide the information they need for their register of information (e.g., locations of service provision and data processing, subcontractors)?	**Show:** List of critical suppliers, contract clauses **2:** Critical suppliers (including IT service providers) are known, security requirements are agreed in contracts **3:** Suppliers are reviewed periodically (e.g., questionnaire, certificates)		

Domain score:

Domain 3 – Security Policies & Processes

ID	Control	Guiding questions	Scoring guidance	Score	Evidence / Notes
3.1	An information security policy exists	• Is an information security policy documented and accessible? • Has it been approved by management? • Is it reviewed regularly?	**Show:** Information security policy with approval **2:** Policy approved and accessible to all employees **3:** Reviewed at least annually and updated after changes		
3.2	Acceptable use policies are defined	• Is an acceptable use policy in place? • Are rules for the use of IT systems and cloud services defined? • Are rules defined for the use of AI tools (e.g., which tools are allowed and which data must not be entered)?	**Show:** Acceptable use policy, including rules for AI tools **2:** Rules for IT, cloud services and AI tools are defined and known **3:** Compliance is checked, rules are updated for new tools		
3.3	Backup policies are documented	• Is a backup policy in place? • Does it define scope, frequency, retention and restore responsibilities?	**Show:** Backup policy **2:** Scope, frequency, retention and responsibilities are defined **3:** Policy is aligned with recovery objectives and reviewed regularly		
3.4	Patch management procedures exist	• Is a patch management process defined? • Does it define timelines based on severity?	**Show:** Patch management procedure **2:** Deadlines by severity are defined (e.g., critical within days) **3:** Compliance with the deadlines is measured and reported		
3.5	Incident response procedures are defined	• Is an incident response procedure documented? • Does it define roles, reporting channels and notification obligations?	**Show:** Incident response procedure **2:** Roles, reporting channels and notification obligations are defined **3:** Procedure is tested and updated after tests or incidents		
3.6	Security responsibilities are agreed with employees, and security procedures are communicated to them	• Are security responsibilities and confidentiality obligations included in employment contracts or separate agreements? • Are background checks performed for roles with access to sensitive information, where legally permitted? • Are employees informed about security policies and procedures, and do they confirm that they have read them?	**Show:** Employment contract template, signed acknowledgements **2:** Security and confidentiality obligations are agreed, employees confirm the rules **3:** Rules are refreshed regularly (e.g., annual confirmation)		

3.7	Payment approvals and changes to bank details are protected against fraud (four-eyes principle, verification through a known contact)	• Are payments above a defined amount approved by two persons? • Are changes to bank details of suppliers or employees verified by calling back a known number (not the contact details in the request)? • Do employees in finance and management know current fraud patterns (e.g., CEO fraud, fake invoices)? • Do they know that voices and videos can be faked with AI (deepfakes), and is the callback through a known number required even if the caller sounds familiar?	**Show:** Payment approval rules, procedure for changes to bank details **2:** Four-eyes principle and callback verification are defined and applied **3:** Procedure is practiced (e.g., in fraud awareness training), exceptions are documented		

Domain score:

Domain 4 – Identity & Access Management (critical)

ID	Control	Guiding questions	Scoring guidance	Score	Evidence / Notes
4.1	User account management is controlled	• Is there a defined process for creating, changing and removing user accounts? • Are all accounts personal (no shared accounts)? • Are passwords protected by clear rules (e.g., password manager, no reuse), and are default passwords on devices such as routers, printers and cameras changed?	**Show:** Joiner, mover and leaver process, user list **2:** Accounts are created and changed only through the defined process, no shared accounts **3:** Process is checked regularly for deviations		
4.2	Role-based access control is implemented	• Are access rights assigned based on roles? • Is the principle of least privilege applied?	**Show:** Role and authorization concept **2:** Access rights are assigned by role and least privilege **3:** Roles are reviewed and adjusted regularly		
4.3	Multi-factor authentication is used for remote access, cloud services and administrative accounts **[KO]**	• Is MFA enforced for remote access, cloud services and email? • Is MFA enforced for all administrative accounts? • Are exceptions documented and approved? • Are phishing-resistant methods (e.g., FIDO2 security keys, passkeys) used for administrators, and is legacy authentication without MFA blocked?	**Show:** MFA configuration (e.g., conditional access policies), list of exceptions **2:** MFA enforced for remote access, cloud services, email and all administrators **3:** Additionally phishing-resistant MFA for administrators, legacy authentication blocked, exceptions reviewed		
4.4	Privileged accounts are restricted and monitored **[KO]**	• Are privileged accounts separated from everyday user accounts? • Is the number of privileged accounts limited? • Is privileged activity logged and reviewed? • Is administrative access by external service providers secured with MFA, limited to what is needed and logged?	**Show:** List of privileged accounts (including service provider accounts) **2:** Separate admin accounts, limited number, MFA, access by service providers controlled **3:** Privileged activity is logged and reviewed regularly		
4.5	Access rights are reviewed periodically	• Are access rights reviewed at defined intervals? • Are review results documented and corrections implemented?	**Show:** Last access review with results **2:** Access rights are reviewed at least annually, corrections are made **3:** Risk-based reviews (more often for critical systems), fully documented		
4.6	User accounts are removed when employees leave	• Are accounts disabled promptly when employees leave or change roles? • Is the process linked to HR?	**Show:** Leaver checklist, sample of recent leavers **2:** Accounts are disabled no later than the last working day **3:** Process is linked to HR and checked by spot checks		

Domain score:

Domain 5 – Infrastructure Security

ID	Control	Guiding questions	Scoring guidance	Score	Evidence / Notes
5.1	An inventory of systems and servers exists	• Is an inventory of servers, systems and cloud resources maintained? • Is it current, and does each system have an owner? • Does the inventory also include network devices, printers, cameras and other IoT or OT devices?	**Show:** System inventory **2:** Inventory is complete and current, each system has an owner **3:** Inventory is updated automatically or regularly checked against reality		
5.2	Secure configuration standards are defined	• Are secure configuration standards (hardening baselines) defined? • Are they based on recognized benchmarks (e.g., CIS Benchmarks)? • Is compliance with the standards checked?	**Show:** Hardening standards, compliance report **2:** Standards are defined and applied to new systems **3:** Compliance is checked regularly (e.g., automated), deviations are fixed		
5.3	Systems are regularly patched and updated **[KO]**	• Are security updates applied within defined timeframes? • Are critical vulnerabilities patched with priority? • Are unsupported systems identified and handled?	**Show:** Patch status report **2:** Updates are applied within the defined deadlines, unsupported systems are known **3:** Patch compliance is measured, unsupported systems are replaced or isolated		
5.4	Administrative access to systems is restricted	• Is administrative access restricted to authorized personnel and dedicated access paths? • Are administrative interfaces protected from direct internet access?	**Show:** Administrative access paths, firewall rules for management interfaces **2:** Admin access only for authorized persons via defined paths, no management interfaces reachable from the internet **3:** Admin access is reviewed regularly (e.g., jump host, time-limited rights)		
5.5	System and software changes are documented and approved, following secure development practices where software is developed or commissioned	• Are changes to systems and software documented and approved? • Is a change management process in place? • If software is developed in-house or commissioned: are secure development practices defined (e.g., secure coding, security testing, separation of development and production)?	**Show:** Change records, secure development guidelines (if applicable) **2:** Changes are documented and approved, secure development practices apply where software is developed **3:** Changes are reviewed for security impact, development practices are checked (e.g., code review, tests)		
5.6	Cloud infrastructure follows secure configuration practices	• Are cloud environments configured according to security best practices? • Is the cloud security posture monitored (e.g., secure score, posture management)? • For cloud and SaaS services (e.g., Microsoft 365): are external sharing and permissions for third-party apps restricted?	**Show:** Cloud security score or configuration report **2:** Cloud and SaaS services follow a defined secure configuration, external sharing is restricted **3:** Configuration is monitored continuously, deviations are fixed		

5.7	Internet-facing systems are known, limited to what is needed and patched with priority	• Is there a current list of all systems and services reachable from the internet (e.g., firewalls, VPN gateways, remote access, websites, mail servers)? • Is the external exposure checked regularly (e.g., external scan), and are services that are not needed closed? • Are security updates for these systems applied within days, especially for actively exploited vulnerabilities?	**Show:** List of internet-facing systems, result of an external scan **2:** All internet-facing systems are known, services not needed are closed, critical updates within days **3:** External exposure is checked regularly (e.g., monthly scan), warnings about actively exploited vulnerabilities are followed		

Domain score:

Domain 6 – Endpoint Security

ID	Control	Guiding questions	Scoring guidance	Score	Evidence / Notes
6.1	Endpoint protection software is deployed	• Is endpoint protection (antivirus or EDR) deployed on all endpoints? • Is its status monitored centrally?	**Show:** Endpoint protection console **2:** Protection is active on all endpoints, status is monitored centrally **3:** Alerts are handled promptly, EDR with response capabilities is in place		
6.2	Devices are centrally managed	• Are devices centrally managed (e.g., MDM/UEM)? • Are compliance policies enforced? • Do users work without local administrator rights, and is the installation of unapproved software (e.g., remote access tools) prevented?	**Show:** Device management console, policies **2:** All devices are centrally managed, users have no local administrator rights **3:** Compliance is enforced (non-compliant devices are blocked), unapproved software is prevented		
6.3	Disk encryption is enabled on endpoints	• Is disk encryption enabled on all laptops and desktops? • Are recovery keys stored securely?	**Show:** Encryption status report **2:** All laptops and desktops are encrypted, recovery keys are stored centrally **3:** Encryption status is monitored, unencrypted devices are detected automatically		
6.4	Endpoint updates are automatically deployed	• Are operating system and application updates deployed automatically? • Is update compliance monitored?	**Show:** Update compliance report **2:** Updates are distributed automatically **3:** Update compliance is monitored, outdated devices are followed up		
6.5	Mobile devices are managed securely	• Are mobile devices managed? • Is company data on personal devices protected?	**Show:** Mobile device management, rules for personal devices **2:** Company smartphones are managed, company data on personal devices is protected (e.g., app protection) **3:** Compliance of mobile devices is checked and enforced		
6.6	Lost or stolen devices can be remotely controlled or wiped	• Can lost or stolen devices be locked or wiped remotely? • Is there a process for reporting lost devices? • Are devices and storage media wiped securely or destroyed before disposal, sale or return (e.g., at the end of a lease)?	**Show:** Remote lock and wipe function, reporting process **2:** Devices can be locked and wiped remotely, loss reporting is defined **3:** Function has been tested, losses are handled within hours		

Domain score:

Domain 7 – Network Security

ID	Control	Guiding questions	Scoring guidance	Score	Evidence / Notes
7.1	Network firewalls are implemented	• Are firewalls deployed at network perimeters? • Are firewall rules reviewed regularly?	**Show:** Firewall rule set, last rule review **2:** Firewalls protect all network perimeters, rules are documented **3:** Rules are reviewed regularly, rules that are not needed are removed		
7.2	Network segmentation is used where appropriate	• Are networks segmented (e.g., servers, clients, guests)? • Are critical systems isolated?	**Show:** Network plan with segments **2:** Servers, clients, guests and (if present) OT or IoT devices are separated **3:** Traffic between segments is restricted to what is needed and reviewed		
7.3	Secure remote access (e.g., VPN or Zero Trust Network Access) is implemented	• Is remote access provided through secure solutions (VPN or ZTNA)? • Is remote access limited to authorized users and devices?	**Show:** Remote access configuration **2:** Remote access only via a secure solution with MFA and for authorized users **3:** Additionally device checks (e.g., ZTNA, compliance check), access is reviewed regularly		
7.4	Network traffic monitoring is performed	• Is network traffic monitored for suspicious activity? • Are intrusion detection or prevention systems used?	**Show:** Monitoring dashboard, example alert **2:** Network traffic is monitored for suspicious activity **3:** Alerts are evaluated and handled, detection rules are maintained		
7.5	Wireless networks are securely configured	• Are wireless networks secured with current encryption (e.g., WPA2/WPA3 Enterprise)? • Is guest Wi-Fi separated from internal networks?	**Show:** Wi-Fi configuration **2:** Current encryption, guest Wi-Fi separated **3:** Enterprise authentication (802.1X), unknown access points are detected		
7.6	Network access is restricted to authorized devices	• Is network access restricted to authorized devices (e.g., NAC, 802.1X)? • Are unknown devices detected?	**Show:** Network access control configuration **2:** Only known devices get network access **3:** Unknown devices are detected and blocked automatically		
7.7	Email is protected against phishing, sender spoofing and malware	• Are incoming emails filtered for phishing, malicious links and attachments? • Are SPF, DKIM and DMARC configured for the organization's domains (DMARC with an enforcing policy)? • Are external emails marked, and can employees report suspicious emails easily?	**Show:** Email filter settings, DMARC record (e.g., DNS lookup) **2:** Filtering active, SPF, DKIM and DMARC configured, external emails marked **3:** DMARC enforced (quarantine or reject), reports are evaluated, reported emails are analyzed		

Domain score:

Domain 8 – Data Protection, Backup & Recovery (critical)

ID	Control	Guiding questions	Scoring guidance	Score	Evidence / Notes
8.1	Sensitive data is identified and classified	• Is sensitive data identified? • Is a data classification scheme in place and applied?	**Show:** Classification scheme, overview of sensitive data **2:** Sensitive data is identified and classified **3:** Classification is applied in daily work (e.g., labels) and reviewed		
8.2	Encryption is used to protect sensitive data based on a defined cryptography policy	• Is a cryptography policy defined (e.g., approved algorithms, key lengths, key management)? • Is sensitive data encrypted at rest and in transit according to this policy? • Are encryption keys managed securely?	**Show:** Cryptography policy, encryption settings **2:** Policy defined, sensitive data encrypted at rest and in transit **3:** Key management is controlled, compliance with the policy is checked		
8.3	Secure file transfer mechanisms are used	• Are secure file transfer methods used (e.g., SFTP, secure sharing platforms)? • Are insecure transfer methods prohibited?	**Show:** Approved transfer methods **2:** Secure methods are available and used, insecure methods are prohibited **3:** Use is monitored (e.g., data loss prevention)		
8.4	Backup procedures are implemented and tested **[KO]**	• Are backups performed according to the backup policy? • Are restores tested regularly and documented? • Are data in cloud and SaaS services (e.g., Microsoft 365) included in the backup?	**Show:** Backup report, record of the last restore test **2:** Backups run as planned, including cloud and SaaS data, restores have been tested **3:** Regular restore tests with measured duration, also for complete systems		
8.5	Backup data is protected from unauthorized access and tampering **[KO]**	• Are backups protected against unauthorized access and ransomware (e.g., offline or immutable copies, separate credentials)? • Is at least one backup copy stored at a separate location?	**Show:** Backup architecture (offline or immutable copy, credentials) **2:** At least one offline or immutable copy at a separate location, separate credentials **3:** Protection is tested (e.g., attack scenario) and monitored		
8.6	Files exchanged or archived outside protected systems are encrypted using current algorithms (e.g., AES-256)	• Are files exchanged or archived outside protected systems encrypted? • Are current algorithms used (e.g., AES-256)?	**Show:** Encryption tool, example of an encrypted exchange **2:** Files outside protected systems are encrypted with current algorithms **3:** Use is enforced technically or checked		
8.7	Business continuity and disaster recovery plans are documented and tested	• Are critical business processes and IT systems identified, with recovery time and recovery point objectives (RTO/RPO)? • Are business continuity and disaster recovery plans documented for these processes and systems? • Are the plans tested regularly (e.g., recovery tests, tabletop exercises), and are the results documented? • If you have customers in the financial sector: are your recovery objectives aligned with the requirements of customers for whom your service is critical, and are the plans tested?	**Show:** Business impact analysis, continuity and recovery plans, test report **2:** Critical processes with RTO/RPO identified, plans documented and tested at least once **3:** Plans are tested at least annually, results lead to improvements		

8.8	Crisis management and emergency communication are defined	• Is a crisis management team with roles and decision authority defined? • Are emergency communication channels defined that work when primary IT systems are unavailable? • Are contact lists for internal and external parties (e.g., authorities, insurers, key suppliers) current?	**Show:** Crisis management plan, contact list (printed or offline) **2:** Crisis team, decision authority and emergency communication defined, contact list current **3:** Crisis exercise conducted, plan and contacts are reviewed regularly		

Domain score:

Domain 9 – Monitoring & Incident Response (critical)

ID	Control	Guiding questions	Scoring guidance	Score	Evidence / Notes
9.1	Security logs are collected	• Are security logs collected from relevant systems? • Are logs stored centrally and retained for a defined period? • Are audit logs of cloud services (e.g., Microsoft 365) enabled and retained long enough?	**Show:** Log sources, retention settings **2:** Logs of relevant systems, including cloud audit logs, are collected centrally and retained **3:** Completeness of log sources is checked regularly		
9.2	Log monitoring is performed	• Are logs monitored? • Is monitoring automated (e.g., SIEM)?	**Show:** Monitoring tool or SIEM, example evaluation **2:** Logs are monitored using defined rules **3:** Monitoring is automated, rules are adapted to new threats		
9.3	Security alerts are reviewed regularly	• Are security alerts reviewed regularly? • Are responsibilities and response times defined?	**Show:** Alert queue, response times **2:** Alerts are reviewed regularly by named persons **3:** Response times defined and met, also outside office hours (e.g., via a service provider)		
9.4	Incident response procedures are documented and operational **[KO]**	• Is an incident response procedure documented and known to responsible staff? • Has it been tested (e.g., tabletop exercise)?	**Show:** Incident response plan, record of the last exercise **2:** Plan documented and known to the responsible persons **3:** Plan is exercised regularly (e.g., tabletop exercise) and updated		
9.5	Security incidents are recorded and investigated	• Are security incidents recorded and investigated? • Are root causes analyzed and lessons learned documented?	**Show:** Incident log, example analysis **2:** Incidents are recorded and investigated **3:** Root causes are analyzed, lessons learned lead to measures		
9.6	Incident escalation and reporting paths, including regulatory reporting obligations, are defined	• Are escalation paths defined, including management and external parties? • Are applicable regulatory reporting obligations and deadlines known (e.g., NIS2: early warning within 24 hours, incident notification within 72 hours, final report within one month)? • Is it defined who reports to authorities and how? • Are data protection notification obligations known (e.g., Swiss FADP: notification to the FDPIC as soon as possible; GDPR: within 72 hours)? • If you have customers in the financial sector: are deadlines and channels for notifying them of incidents defined, and can you support them in handling incidents?	**Show:** Overview of escalation and notifications (who, when, to whom) **2:** Escalation paths, notification obligations and deadlines (e.g., NIS2, data protection) are known, responsibilities defined **3:** Notification process is practiced, report templates are prepared		

Domain score:

Domain 10 – Continuous Improvement

ID	Control	Guiding questions	Scoring guidance	Score	Evidence / Notes
10.1	Security reviews are conducted periodically	• Are security reviews conducted at defined intervals? • Are the results documented?	**Show:** Last security review with results **2:** Reviews take place at defined intervals and are documented **3:** Results lead to tracked measures		
10.2	Security audits or assessments are performed	• Are internal or external security audits performed? • Are findings tracked?	**Show:** Audit report, list of findings **2:** Audits or assessments are performed, findings are recorded **3:** Findings are tracked to closure, independent audits take place periodically		
10.3	Vulnerabilities are identified through regular assessments, and reported vulnerabilities are handled	• Are vulnerability scans or penetration tests conducted regularly? • Are findings remediated? • Is there a process for receiving and handling vulnerability reports from external parties (e.g., security contact, vulnerability disclosure policy)? • If you have customers in the financial sector: can you support them in resilience and penetration tests (e.g., participation in threat-led penetration tests)?	**Show:** Latest scan or penetration test report, security contact **2:** Vulnerability scans at least quarterly, findings are remediated, reports from third parties can be received **3:** Remediation deadlines are measured, regular penetration tests, published security contact (e.g., security.txt)		
10.4	Improvement actions are tracked	• Are improvement actions tracked with owners and deadlines? • Is progress reported?	**Show:** Action list with status **2:** Improvement actions have owners and deadlines **3:** Progress is reported to management regularly		
10.5	Security awareness training is provided to employees and management	• Do all employees receive security awareness training? • Do members of management receive cybersecurity training (e.g., as required by NIS2 Art. 20(2))? • Are phishing simulations conducted, and is participation tracked? • Does the training cover AI-supported attacks such as convincing phishing emails and deepfakes?	**Show:** Training records, including management **2:** All employees and management are trained at least annually **3:** Phishing simulations, role-specific training (e.g., finance, IT) and measured results		
10.6	Security metrics or KPIs are evaluated	• Are security metrics or KPIs defined? • Are they evaluated and reported?	**Show:** Overview of metrics **2:** Security metrics are defined and evaluated **3:** Metrics have target values and lead to decisions		

Domain score:

Domain 11 – AI Security (if applicable; critical when applicable)

This domain applies as soon as AI systems are developed, operated or used, including AI services such as AI assistants or chat tools used by employees. Control 11.7 is not applicable if no AI agents or AI integrations with access to company data or systems are used.

ID	Control	Guiding questions	Scoring guidance	Score	Evidence / Notes
11.1	AI systems are identified and inventoried, with defined owners	• Are AI systems and AI services in use identified and inventoried? • Are AI functions in existing software (e.g., assistants in office or CRM software), browser extensions and AI agents included? • Does each AI system have a defined owner?	**Show:** AI inventory (including AI services used by employees and AI functions in existing software) **2:** AI systems and services in use are inventoried, each has an owner **3:** Inventory is updated when new tools are introduced, unapproved use is detected		
11.2	AI security risks are assessed	• Are AI-specific risks assessed (e.g., data leakage, prompt injection, model manipulation)? • Does the assessment consider that AI can be manipulated through content it processes (e.g., emails, websites or documents with hidden instructions)? • Are regulatory requirements (e.g., EU AI Act) considered? • If the organization develops or operates its own AI applications (e.g., a chatbot on its website): are they tested against AI-specific attacks before going live and after changes (e.g., based on the OWASP Top 10 for LLM Applications)?	**Show:** AI risk assessment, test results for own AI applications **2:** AI-specific risks (e.g., data leakage, prompt injection) are assessed, regulatory requirements considered, own AI applications are tested before going live **3:** Assessment is repeated for new use cases and changes, own AI applications are retested after changes		
11.3	AI usage policies and security controls are defined and implemented	• Are AI usage policies defined and communicated? • Are technical guardrails and access controls implemented for AI systems? • Are access rights to company data reviewed and cleaned up before AI assistants with access to this data are introduced? • Are employees trained in the safe use of AI tools (in the EU also required as AI literacy under Art. 4 of the EU AI Act)?	**Show:** AI usage policy, guardrail and access settings, training records **2:** Policy defines allowed tools and data, access is controlled, employees are trained **3:** Technical safeguards (e.g., data loss prevention, restricted connectors) enforce the policy, access rights are reviewed before AI assistants are introduced		
11.4	AI systems are monitored for security events and unexpected behavior	• Are AI systems monitored for security events? • Is unexpected behavior detected and reviewed? • Do logs show who used which AI system and, where legally permitted, which inputs and outputs were processed? • Are usage and cost limits defined so that misuse and unexpected consumption are noticed?	**Show:** AI monitoring or audit logs **2:** Use and security events of AI systems are logged and monitored **3:** Unexpected behavior is detected and evaluated systematically		

11.5	AI security incidents are investigated	• Are AI-related security incidents recorded and investigated? • Does the incident process cover AI-specific cases (e.g., confidential data entered into an AI tool, a manipulated AI agent)?	**Show:** Incident records related to AI **2:** AI incidents are part of the incident process **3:** Lessons learned lead to adjustments of AI policies and controls		
11.6	AI security is included in management reporting and continuous improvement	• Is AI security included in management reporting? • Is AI security part of continuous improvement activities?	**Show:** Management report with an AI section **2:** AI security is part of management reporting **3:** AI security has its own objectives and metrics within continuous improvement		
11.7	AI agents and AI integrations have only the access rights they need, and critical actions require human approval	• Are AI agents or AI integrations with access to company data or systems used at all? If not, this control is not applicable (N/A). • Which actions can AI agents, assistants or integrations perform on their own (e.g., send emails, change files, trigger payments)? • Do they use their own accounts with limited, task-specific rights instead of administrator or personal accounts with broad access? • Do critical actions (e.g., payments, mass emails, deleting data, changes to systems) require human approval? • Are approvals limited to actions that are really critical, so that they are checked carefully and not confirmed out of habit? • Are only approved connectors, plugins and extensions used, and can an agent be stopped quickly?	**Show:** Overview of AI agents and integrations with their rights, approval settings **2:** Rights are limited to the task, critical actions require approval, only approved connectors are used **3:** Rights are reviewed regularly, agent actions are logged, agents can be stopped immediately		
11.8	AI services and AI providers are assessed before use	• Is it checked before use whether the provider uses entered data for training, where and for how long data is stored and who can access it? • Are business versions with contractual data protection used for company data instead of free consumer versions? • Are certifications or attestations of the provider considered (e.g., ISO/IEC 27001, ISO/IEC 42001, BSI C5 or AIC4)? • If AI models are downloaded and run locally (e.g., freely available open-weight models): are they obtained only from trusted sources and approved before use?	**Show:** Provider assessment, contract or terms of use, data processing agreement, list of approved AI services and models **2:** AI services are approved only after checking data use, storage location and contract; locally operated models come from trusted sources **3:** Providers are reviewed periodically and when terms change		

11.9	AI-generated results are reviewed by people before they are used for important decisions, published or put into production	• Is it defined which AI results must be reviewed by a person (e.g., contracts, customer communication, published content, program code, decisions about people)? • Is it clear that responsibility for a result stays with the person who uses it? • Is AI-generated program code reviewed and tested like other code before it is used?	**Show:** Rules for reviewing AI results, examples of reviews **2:** Review requirements are defined and known, responsibility is clear **3:** Compliance is checked in samples, errors found lead to adjustments of the rules		

Domain score:

Result Summary

Domain	Critical	Score
1. Business & Security Governance	Yes	
2. Risk Management		
3. Security Policies & Processes		
4. Identity & Access Management	Yes	
5. Infrastructure Security		
6. Endpoint Security		
7. Network Security		
8. Data Protection, Backup & Recovery	Yes	
9. Monitoring & Incident Response	Yes	
10. Continuous Improvement		
11. AI Security (if applicable)	Yes	

Overall ACP score:

ACP maturity level:

Knock-out control scored 0: □ No □ Yes (ID:)